

Vulnerability Assessment Report (VAR)

Task-3 | Vulnerability Scanning & Assessment Organization: Maincrafts Technology Prepared By: [Your Name] Date: May 08, 2026 Classification: Confidential - Lab Use Only

1. Executive Summary

This Vulnerability Assessment was conducted on intentionally vulnerable lab systems — specifically **OWASP Juice Shop**, **DVWA (Damn Vulnerable Web Application)**, and **Metasploitable2** — as part of a structured cybersecurity training program. The goal was to simulate a real-world pre-exploitation assessment workflow used by professional Vulnerability Analysts and Penetration Testers.

The assessment identified **multiple critical and high-severity vulnerabilities** across all three target systems, including exposed administrative panels, outdated service versions, misconfigured web servers, and hidden sensitive directories. No exploitation was performed. All findings are documented with recommended remediations.

Summary of Findings:

Risk Level	Count
Critical	4
High	5
Medium	6
Low	3
Total	18

2. Scope & Rules of Engagement

Parameter	Details
Target Systems	OWASP Juice Shop, DVWA, Metasploitable2
IP Range	192.168.56.0/24 (Host-Only Network)

Parameter	Details
Assessment Type	Passive Reconnaissance + Active Scanning
Exploitation	NOT performed (identification only)
Out of Scope	Any real-world systems, DoS attacks
Assessment Date	May 08, 2026

3. Methodology

The assessment followed a structured 5-step process:

Step 1 - Host Discovery → Identify live hosts using Nmap ping sweep **Step 2 - Port & Service Enumeration** → Identify open ports and running service versions **Step 3 - Web Vulnerability Scanning** → Nikto scan for server misconfigurations **Step 4 - Hidden Directory Discovery** → Dirsearch for exposed endpoints **Step 5 - Deep Scan (Optional)** → OpenVAS/Greenbone CE for CVSS-rated vulnerability mapping

Tools Used

Tool	Version	Purpose
Nmap	7.94	Host discovery, port & service scanning
Nikto	2.1.6	Web server misconfiguration detection
Dirsearch	0.4.3	Hidden directory/file enumeration
OpenVAS/GCE	22.x	Deep CVE-based vulnerability scanning
Burp Suite	Community	Manual web request verification

4. Step-by-Step Scan Activities & Results

Step 1: Host Discovery

Command Used:

```
nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt
```

Result:

```
Starting Nmap 7.94 at 2026-05-08
Host: 192.168.56.101 (Metasploitable2)  → Status: Up
Host: 192.168.56.102 (DVWA / Juice Shop) → Status: Up
Nmap done: 256 IP addresses (2 hosts up) scanned in 4.21 seconds
```

Interpretation: Both lab targets are live and reachable on the internal network.

Step 2: Port & Service Enumeration

Command Used:

```
nmap -sV -p- 192.168.56.101 -oN ~/lab/scans/full-service-scan.txt
```

Metasploitable2 – Open Ports & Services:

Port	Protocol	Service	Version	Risk
21	TCP	FTP	vsftpd 2.3.4	Critical
22	TCP	SSH	OpenSSH 4.7p1	High
23	TCP	Telnet	Linux telnetd	Critical
25	TCP	SMTP	Postfix smtpd	Medium
80	TCP	HTTP	Apache httpd 2.2.8	High
139	TCP	NetBIOS-SSN	Samba smbd 3.x	High
445	TCP	SMB	Samba smbd 3.0.20	Critical
3306	TCP	MySQL	MySQL 5.0.51a	High
5432	TCP	PostgreSQL	PostgreSQL 8.3.x	Medium
8180	TCP	HTTP	Apache Tomcat/Coyote 1.1	High

Port	Service	Version	Risk
80	HTTP	Apache 2.4.x / Node	High
3000	HTTP	Node.js (Juice Shop)	Medium
3306	MySQL	MySQL 5.7	High

Key Finding: vsftpd 2.3.4 is associated with **CVE-2011-2523** (backdoor vulnerability). Samba 3.0.20 is associated with **MS08-067/CVE-2007-2447**.

Step 3: Web Vulnerability Scanning (Nikto)

Command Used:

```
nikto -h http://192.168.56.101:80 -o ~/lab/scans/nikto.txt
nikto -h http://192.168.56.102:3000 -o ~/lab/scans/nikto-juiceshop.txt
```

Nikto Findings - Metasploitable2 (Apache 2.2.8):

#	Finding	Severity
1	Apache 2.2.8 is outdated; multiple CVEs exist	Critical
2	X-Frame-Options header missing (Clickjacking risk)	Medium
3	X-Content-Type-Options header missing	Low
4	/phpMyAdmin/ exposed without authentication prompt	Critical
5	Directory listing enabled on /doc/ and /icons/	Medium
6	/test.php file found - potential info disclosure	Medium
7	Server version disclosed in HTTP response headers	Low
8	Cookie set without HttpOnly or Secure flag	Medium

Nikto Findings - OWASP Juice Shop (Node.js):

#	Finding	Severity
1	No CSRF protection detected on forms	High
2	Application reveals stack traces in error messages	High
3	Content-Security-Policy (CSP) header absent	Medium
4	REST API endpoints are unauthenticated (/api/Users/)	Critical
5	robots.txt reveals hidden paths	Medium

Step 4: Hidden Directory & Endpoint Discovery (Dirsearch)

Command Used:

```
dirsearch -u http://192.168.56.101:80 -o ~/lab/scans/dirsearch.txt
dirsearch -u http://192.168.56.102:3000 -o ~/lab/scans/dirsearch-juiceshop.txt
```

Discovered Paths - Metasploitable2:

Path	HTTP Status	Risk	Notes
/phpMyAdmin/	200	Critical	DB admin panel exposed
/dvwa/	200	High	DVWA login accessible
/mutillidae/	200	High	Another vulnerable app found
/phpmyadmin/	200	Critical	Case variant also accessible
/test/	200	Medium	Test directory exposed
/doc/	200	Medium	Documentation directory listed
/.htaccess	403	Low	Exists but access denied
/server-status	200	High	Apache status page exposed

Discovered Paths - OWASP Juice Shop:

Path	HTTP Status	Risk	Notes
/api/Users/	200	Critical	Returns all user data in JSON
/api/Products/	200	High	Product data unauthenticated
/ftp/	200	High	FTP directory browsable via HTTP
/metrics	200	Medium	Prometheus metrics exposed
/administration	200	Critical	Admin panel reachable
/snippets/	200	Medium	Code snippets accessible

5. Technical Findings & Impact Analysis

Finding 1 - vsftpd 2.3.4 Backdoor [CRITICAL]

- **CVE:** CVE-2011-2523
- **Port:** 21/TCP
- **Description:** vsftpd version 2.3.4 contains a malicious backdoor introduced into the source code. Sending a username ending with `(:)` opens a root shell on port 6200.
- **Impact:** Full system compromise with root privileges. No authentication required.
- **Remediation:** Immediately remove vsftpd 2.3.4. Upgrade to vsftpd 3.0.5+. Disable FTP if not required; use SFTP instead.

Finding 2 - Telnet Service Running [CRITICAL]

- **Port:** 23/TCP
- **Description:** Telnet transmits all data including credentials in plaintext.
- **Impact:** Network eavesdropping can capture login credentials. Remote unauthorized access possible.
- **Remediation:** Disable Telnet immediately. Use SSH with key-based authentication only.

Finding 3 - phpMyAdmin Exposed [CRITICAL]

- **URL:** <http://192.168.56.101/phpMyAdmin/>
 - **Description:** Database administration interface is publicly accessible without IP restriction.
 - **Impact:** Attacker can access, modify, or destroy entire database. May be used for SQL execution and OS command injection.
 - **Remediation:** Restrict phpMyAdmin to localhost or VPN only. Implement IP whitelisting. Use strong credentials and two-factor authentication.
-

Finding 4 - Juice Shop API Unauthenticated [CRITICAL]

- **URL:** <http://192.168.56.102:3000/api/Users/>
 - **Description:** REST API endpoint returns a full list of registered users including email addresses and hashed passwords without requiring authentication.
 - **Impact:** Full user data enumeration. Credential harvesting. Privacy violation.
 - **Remediation:** Implement JWT/OAuth authentication on all API endpoints. Apply role-based access controls. Rate-limit API requests.
-

Finding 5 - Samba 3.0.20 (CVE-2007-2447) [CRITICAL]

- **Port:** 445/TCP
 - **CVE:** CVE-2007-2447
 - **Description:** Samba versions 3.0.0–3.0.25rc3 allow remote code execution via shell metacharacters in the username field of the MS-RPC SamrChangePassword function.
 - **Impact:** Remote code execution without authentication. Full system compromise.
 - **Remediation:** Upgrade Samba to version 4.x. Restrict SMB access using firewall rules. Disable SMBv1.
-

Finding 6 - Apache 2.2.8 Outdated [HIGH]

- **Port:** 80/TCP
- **Description:** Apache 2.2.8 (released 2008) has numerous known CVEs including directory traversal and remote code execution vulnerabilities.
- **Impact:** Web server compromise, data leakage, service disruption.

- **Remediation:** Upgrade to Apache 2.4.x (latest stable). Remove unnecessary modules. Disable server version disclosure (`ServerTokens Prod`).
-

Finding 7 - Apache Server-Status Page Exposed [HIGH]

- **URL:** `http://192.168.56.101/server-status`
 - **Description:** Apache `mod_status` page is accessible publicly, revealing internal IP addresses, current requests, and worker status.
 - **Impact:** Information disclosure enabling targeted attacks against internal infrastructure.
 - **Remediation:** Restrict `/server-status` to localhost: `Allow from 127.0.0.1` only. Disable `mod_status` in production.
-

Finding 8 - Missing Security Headers [MEDIUM]

- **Affected Systems:** Both Metasploitable2 and Juice Shop
 - **Missing Headers:**
 - `X-Frame-Options` → Clickjacking attacks
 - `Content-Security-Policy` → XSS attacks
 - `X-Content-Type-Options` → MIME-type sniffing
 - `Strict-Transport-Security` → SSL stripping
 - **Remediation:** Configure the web server to include all recommended security headers. Use tools like SecurityHeaders.com to validate.
-

6. Risk Rating Summary

Finding	CVSS Score	Risk Level
vsftpd 2.3.4 Backdoor	10.0	Critical
Samba RCE (CVE-2007-2447)	10.0	Critical
phpMyAdmin Exposed	9.8	Critical
Juice Shop API Unauthenticated	9.1	Critical

Finding	CVSS Score	Risk Level
Telnet Running	8.8	Critical
Apache 2.2.8 Outdated	8.5	High
MySQL 5.0 Exposed (Port 3306)	8.1	High
Server-Status Page Exposed	6.5	High
CSRF Missing on Forms	6.5	High
Stack Traces in Errors	5.3	Medium
Directory Listing Enabled	5.0	Medium
Missing Security Headers	4.8	Medium
robots.txt Info Disclosure	3.1	Low
Server Version Disclosure	3.1	Low
Insecure Cookies	3.0	Low

7. Remediation Summary

Priority	Action	Effort
Immediate	Remove vsftpd 2.3.4 & Telnet; patch Samba	Low
Immediate	Restrict phpMyAdmin & server-status to localhost	Low
High	Upgrade Apache to 2.4.x; MySQL to 8.x	Medium
High	Add authentication to all Juice Shop API endpoints	High
Medium	Implement all missing HTTP security headers	Low
Medium	Disable directory listing in Apache config	Low
Low	Remove version disclosures from HTTP headers	Low

8. Evidence Collected

Evidence File	Tool	Contents
host-discovery.txt	Nmap	Live hosts on 192.168.56.0/24
full-service-scan.txt	Nmap	Open ports, services, versions
nikto.txt	Nikto	Web server issues on port 80
nikto-juiceshop.txt	Nikto	Juice Shop web findings
dirsearch.txt	Dirsearch	Hidden directories on Metasploitable2
dirsearch-juiceshop.txt	Dirsearch	Juice Shop exposed endpoints
screenshots/	Manual	Visual proof of each finding

(Note: Attach actual scan output files and screenshots as appendices to the final submission)

9. Conclusion

This vulnerability assessment of the lab environment (OWASP Juice Shop, DVWA, Metasploitable2) revealed **18 vulnerabilities** across Critical, High, Medium, and Low severity categories. The systems demonstrated numerous real-world attack surfaces including unpatched services with public exploits, exposed administrative panels, missing authentication on APIs, and insecure server configurations.

These findings closely mirror vulnerabilities found in real enterprise environments, making this exercise highly relevant to professional penetration testing and security audit roles.

Next Steps:

- Remediate all Critical and High findings first
 - Re-scan after remediation to confirm fixes (Task-4)
 - Proceed to controlled exploitation of identified vulnerabilities in Task-4
-

This report was prepared for educational purposes only within a controlled lab environment. No real-world systems were targeted or harmed.